

Fingerprinting antes que el nombre del puerto

Objetivos de aprendizaje

Identificar la superficie, explicar la causa, diseñar una confirmación mínima, interpretar evidencia y proponer una mitigación causal.

Prerrequisitos

Flujo source-transformación-validación-sink, parsers, permisos y metodología de hipótesis. Revisa los prerrequisitos declarados en los metadatos.

Fundamentos técnicos

IANA y Nmap pueden asociar un puerto a un nombre habitual, pero cualquier proceso puede escuchar ahí. Fingerprinting es identificar lo que realmente responde mediante handshake, cabeceras, banner, TLS y detección de versión.

Asumir que 5050 es 'mmcc' puede hacer que ignores una web Flask o Werkzeug. El servicio real determina tus siguientes pruebas: HTTP se enumera con rutas, formularios y cabeceras; SSH con usuarios y credenciales; no con el nombre histórico del puerto.

Modelo mental

```
Entrada controlada -> transformaciones -> validación -> componente final  
                    -> sink -> efecto observable -> decisión
```

El paso crítico es demostrar qué componente consume el valor y con qué identidad o privilegios.

Superficie de ataque

Siempre que encuentres un puerto no estándar, un banner incompleto o una asociación de Nmap que no encaje con la respuesta observada.

Cómo identificarla

- Un puerto alto o raro responde con cabeceras HTTP.
- El nombre de servicio de Nmap no coincide con el banner o con el comportamiento.
- -sV identifica un producto/framework distinto de la asociación por puerto.

Preguntas que debo hacerme

- ¿Qué dato controlo exactamente y en qué formato viaja?
- ¿Qué transformaciones y normalizaciones ocurren antes del sink?
- ¿Qué identidad ejecuta la operación y qué permisos tiene?
- ¿Qué otra explicación produciría la misma señal?
- ¿Cuál es la prueba de menor riesgo que separa ambas explicaciones?

Prueba mínima

Nmap -sV, curl o una conexión de protocolo devuelve una respuesta coherente con el servicio real.

Evidencia esperada: Tienes protocolo, producto y versión para decidir la enumeración y buscar vulnerabilidades aplicables.

Construcción progresiva del payload

1. Reproduce una entrada válida.
2. Aísla un único valor controlable.

3. Define la primitiva mínima indicada por la fuente.
4. Predice resultado y control negativo.
5. Aplica una sola adaptación cuando haya evidencia de restricción.
6. Confirma de forma reproducible antes de ampliar impacto.

Capa 1: prueba documentada

```
nmap -sC -sV -Pn -p <PUERTO> $IP
```

Objetivo y contexto: Confirma que habla realmente el puerto y recoge scripts/banners utiles.

Resultado esperado: Servicio, producto, version y pistas como titulos HTTP o certificados.

Capa 2: prueba documentada

```
curl -i http://$IP:<PUERTO>/
```

Objetivo y contexto: Una comprobacion HTTP directa separa una aplicacion web real de una etiqueta de puerto equivocada.

Resultado esperado: Status, cabeceras y posiblemente framework o rutas a enumerar.

Anatomía de los payloads

La primera prueba es `nmap -sC -sV -Pn -p <PUERTO> $IP`. Separa sus delimitadores, operadores, opciones, operandos y variables; algunos elementos no estarán presentes según el contexto. Las comillas, barras y separadores pertenecen a una capa concreta. Usa la explicación de cada capa para determinar qué símbolo altera sintaxis y cuál transporta datos.

Variaciones según el contexto

No traslades una prueba entre sistemas operativos, motores, frameworks o versiones sin revisar sintaxis y comportamiento. Conserva la primitiva y vuelve a serializarla para el parser real.

Filtros y bypasses

No existe un bypass universal. Registra la forma enviada, la forma decodificada, la comparación, la normalización y la forma consumida. Una adaptación es válida solo si demuestra una discrepancia concreta; si la validación ocurre sobre la forma canónica y expresa la propiedad correcta, la variante no debe funcionar.

Evidencias de confirmación

Tienes protocolo, producto y version para decidir la enumeracion y buscar vulnerabilidades aplicables.

Usa además una entrada inocua y un control negativo. No confundas reflexión, error genérico o demora aislada con confirmación.

Escalado de impacto

- Registra el puerto abierto sin asumir su funcion.
- Ejecuta deteccion de version y observa la respuesta de protocolo.
- Enumera segun el servicio confirmado y no segun el alias del puerto.
- Guarda producto y version exactos como evidencia para el siguiente paso.

Amplía únicamente dentro del laboratorio y cuando cada salto aporte una capacidad nueva demostrable.

Errores frecuentes

- No sustituyas una identificacion de version fiable por el nombre del puerto.
- No concluyas que un servicio esta ausente solo porque no usa su puerto por defecto.
- Ejecutar la prueba sin adaptar variables ni versión.

- Cambiar varias capas a la vez.
- Omitir el control negativo o no guardar evidencia.

Diagnóstico de payloads fallidos

Síntoma	Posible causa	Prueba de diagnóstico	Adaptación
Rechazo inmediato	Formato o precondition	Repetir entrada válida	Corregir transporte
Sin diferencia	Entrada ignorada o canal ciego	Marcador y control negativo	Buscar evidencia adecuada
Error del componente	Contexto o versión	Reducir a prueba mínima	Consultar manual detectado
Resultado parcial	Permisos/restricción	Comprobar identidad y alcance	Reducir primitiva

Mitigaciones

Eliminar el dato controlable del sink cuando sea posible; usar APIs estructuradas, allowlists sobre valores canónicos, privilegio mínimo, autorización en servidor y registros que permitan detectar abuso. La defensa concreta debe impedir la causa explicada en Fundamentos técnicos.

Relación con pentesting y certificaciones

Se espera reconocer la señal, justificar la prueba elegida, adaptar variables, interpretar salida y documentar impacto y mitigación. La puntuación debe premiar razonamiento y evidencia, no memoria literal.

Caso guiado

Parte de una señal de la lista anterior. Escribe observación e hipótesis, ejecuta la prueba mínima, compara con el control y clasifica el resultado como no confirmado, indicio o confirmación. Solo entonces sigue los pasos de escalado relevantes.

Caso de adaptación

Si la prueba básica falla, no cambies caracteres al azar. Comprueba primero transporte, parser, versión, permisos y canal de evidencia. Diseña una segunda prueba que discrimine entre las dos causas más probables.

Ejercicios

1. Señala source, transformaciones y sink en el caso guiado.
2. Explica qué evidencia refutaría la hipótesis.
3. Descompón la primera prueba documentada por opciones y argumentos.
4. Propón un control negativo y una mitigación causal.

Resumen

El nombre asignado a un puerto es una pista, no una identidad: confirma protocolo, producto y version antes de elegir la enumeracion. La técnica queda confirmada solo cuando una prueba mínima produce la evidencia prevista y descarta explicaciones alternativas.

Chuleta operativa

1. Confirmar alcance y condiciones.
2. Identificar entrada, componente y permisos.
3. Ejecutar prueba mínima y control.
4. Interpretar señal antes de escalar.

5. Guardar evidencia y mitigación.

Referencias

- [Concepto fuente de THM Fieldbook](#) (fingerprinting-servicios)
- [Referencia técnica externa](#)

Navegación

Anterior: [Construcción de payloads](#). Índice: [curso](#). Ejercicios y chuleta se enlazarán desde la matriz de trazabilidad.